

BUSINESS CONTINUITY PLAN

ShopEase Online Retail

CIS4365 – Enterprise Cybersecurity

Version	v1.0
Date	April 8, 2026
Owner	Business Continuity & DR Manager
Classification	CONFIDENTIAL – Internal Use Only
Status	APPROVED – Active

Prepared by: Aykhan Pashayev | Reviewed by: Christian Acevedo, CISO

1. Document Control

Field	Details
Document Title	Business Continuity Plan — ShopEase Online Retail
Version	v1.0
Effective Date	April 8, 2026
Document Owner	Business Continuity & DR Manager
Executive Sponsor	Christian Acevedo, CISO
Operations Lead	E-Commerce & Web Development Manager
IT Lead	IT & Cloud Operations Manager
Compliance/Risk	Fraud Prevention & Compliance Team Lead
Distribution	CISO, IT & Cloud Ops, DevOps, Fraud & Compliance, Customer Support Lead, Warehouse Ops Lead
Review Cadence	Annual, or after any major incident, infrastructure change, or vendor change
BIA Reference	Business Impact Analysis — ShopEase Online Retail v1.0 (attached as Appendix)

2. Purpose, Scope & Objectives

2.1 Purpose

This Business Continuity Plan (BCP) defines how ShopEase Online Retail will sustain essential business operations during and immediately following a disruptive event. The BCP ensures that critical revenue-generating and compliance-obligated processes remain operational at a minimal viable level until full restoration is achieved through the Disaster Recovery Plan (DRP).

2.2 Scope

In Scope:

- All mission-critical business processes: Online Selling, Payment & Fraud Processing, Inventory Management, Customer Support, IT & Cloud Operations
- Physical sites: HQ (office & customer service) and Warehouse/Distribution Center
- AWS-hosted cloud infrastructure (EC2, RDS, WAF, CloudFront, Load Balancers, SIEM)
- Third-party dependencies: AWS, third-party PCI payment gateway, FedEx/UPS shipping partners, SaaS tools
- All ~150 staff endpoints, workstations, VoIP, and warehouse terminals
- Data types in scope: Customer PII, order history, payment metadata, inventory data

Out of Scope:

- Full system restoration and DR rebuild (covered by the DRP)
- Marketing analytics platforms (non-critical, Medium/Low priority)
- HR and payroll systems (non-customer-facing; separate continuity plan)

2.3 Objectives

- Sustain Tier-1 processes (Payment Processing, Online Selling) within BIA-defined MTD thresholds
- Meet RTO of 2 hours for Payment Processing and 4 hours for E-Commerce Platform
- Ensure data loss does not exceed RPO of 15 minutes for Payment Processing and 30 minutes for the E-Commerce Platform
- Maintain PCI-DSS compliance obligations during and after any disruption
- Protect customer trust and minimize reputational and financial damage
- Provide clear activation authority, communication procedures, and recovery handoff criteria

3. Alignment to the BIA

This BCP is derived directly from the ShopEase Business Impact Analysis (BIA v1.0). The BIA identified critical processes, time objectives, dependencies, and regulatory constraints that form the requirements for this plan.

3.1 Critical Process Priority Matrix

Process	Owner	MTD	RTO	RPO	Key Dependencies	Minimal Viable Capability
Payment Processing	Finance / Fraud	8h	2h	15min	Payment Gateway, AWS Backend, Fraud Scoring Engine, PCI-DSS Artifacts	Activate secondary payment gateway; redirect to manual order capture with delayed processing
E-Commerce Platform	E-Commerce & DevOps	12h	4h	30min	AWS EC2, CloudFront, WAF, Load Balancer, Product Search API, RDS Database	Failover to backup AWS region; static 'maintenance mode' page with order phone line
Inventory Management	Warehouse Ops	48h	24h	4h	Inventory DB, Barcode Scanners, Pick/Pack Terminals, Distribution Center	Manual stock sheets; warehouse staff record picks manually; batch sync on recovery
Customer Support	Support Team	72h	24h	12h	VoIP, CRM Ticketing System, Workstations	Redirect to email-only support; agents work remotely with limited CRM access
IT & Cloud Operations	IT/DevOps	N/A	Continuous	N/A	AWS Console, SIEM, IAM, VPN, Monitoring Dashboards	Maintain VPN + MFA access; cloud monitoring always-on; IaC ready for redeploy

Tier Legend:

Tier	Priority	Processes
1	CRITICAL	Payment Processing, E-Commerce Platform
2	HIGH	Inventory Management
3	MEDIUM	Customer Support, IT & Cloud Ops

4. Activation & Disaster Declaration

4.1 Activation Triggers

The BCP is activated when any of the following conditions occur:

- Any Tier-1 process (Payment Processing or E-Commerce) is disrupted beyond 2 hours with no clear path to rapid restoration
- The AWS primary region hosting ShopEase's workloads becomes inaccessible or degraded beyond SLA
- Third-party payment gateway is confirmed unavailable for more than 1 hour during business hours
- A security incident (e.g., confirmed ransomware, SQL injection causing data breach) causes sustained system unavailability
- Physical site (HQ or Warehouse) becomes inaccessible due to natural disaster, fire, or safety event
- A critical vendor (AWS, payment gateway) declares a major outage affecting ShopEase systems
- Any event causing or threatening to cause financial loss ≥ \$25,000/hour through system unavailability

4.2 Authority to Activate

Authority Level	Role	Condition
Primary	CISO (Christian Acevedo)	Major incident confirmed; Tier-1 process down > 1 hour
Secondary	IT & Cloud Operations Manager	CISO unreachable; confirmed outage per above triggers
Emergency	On-Call SOC Lead (Mathias Benkert)	After-hours; CISO and IT Lead unreachable; SEV1 event active

4.3 Initial Actions Upon Activation

Step 1 — Declare & Notify (within 15 minutes of activation decision):

- BCP Coordinator sends activation notice via pre-established emergency phone tree and Slack/email
- All department leads acknowledge receipt and begin process-level continuity runbooks

- Virtual Emergency Operations Center (EOC) is stood up via video bridge

Step 2 — Assess & Triage (within 30 minutes):

- IT Lead confirms scope of technical failure and provides an initial ETA for restoration
- BCP Coordinator confirms which processes are affected and their current operational status
- Vendor Manager contacts AWS, payment gateway, and shipping partners for status updates

Step 3 — Execute Continuity Strategies (within 1 hour):

- Each process owner activates their specific continuity strategy (Section 6)
- Compliance/Legal notified immediately if payment data, PCI metadata, or PII may be affected
- Communications plan activated per Section 9

4.4 Deactivation Criteria

- Primary systems are restored and verified stable for ≥ 30 minutes
- Data integrity checks confirm no unreconciled data loss beyond RPO thresholds
- IT Lead formally confirms DRP handoff complete and primary services operational
- CISO approves BCP deactivation and issues all-clear notification to staff

5. Roles & Responsibilities

Role	Name / Team	Key Responsibilities
BCP Coordinator	CISO – Christian Acevedo	Overall BCP activation authority; executive communications; escalation decisions; regulatory notification sign-off
Operations Lead	E-Commerce Manager	Directs process-level workarounds for Online Selling; coordinates with DevOps on WAF/scaling; validates manual fallback order capture
IT Lead / SOC Lead	Mathias Benkert (SOC)	Manages technical containment; WAF tuning; cloud failover; SIEM monitoring; coordinates with AWS support; leads DRP handoff
Vendor Manager	IT & Cloud Ops	Manages AWS, payment gateway, FedEx/UPS contacts; enforces SLAs; activates secondary payment gateway if needed
Finance / Fraud Lead	Fraud Prevention Team	Monitors for fraudulent transactions during degraded state; PCI-DSS reporting and compliance obligations; manual payment reconciliation
Warehouse Ops Lead	Warehouse Manager	Implements manual inventory logging; coordinates pick/pack with paper-based fallback; communicates with shipping partners
Customer Support Lead	Support Team Lead	Redirects customers to alternate contact channels; manages ticket backlog; provides customer-facing status updates

Role	Name / Team	Key Responsibilities
Compliance / Legal	Legal/Privacy Lead (TBD)	Triggers regulatory notices (PCI-DSS, state breach laws); drafts customer notifications; reviews PR statements; manages legal exposure

6. Continuity Strategies by Process

The following strategies define how ShopEase operates at a 'minimal viable' level during disruptions. These are interim measures only — full restoration follows DRP activation.

6.1 Payment Processing (Tier 1 – CRITICAL)

Element	Details
Primary Threat Scenario	Payment gateway outage, SQL injection disrupting checkout, third-party API failure
Continuity Strategy	Activate secondary/backup PCI-compliant payment gateway; if unavailable, enable manual order capture queue for later processing
Manual Workaround	Agents collect order info via phone/email; payment taken via alternate gateway or deferred with customer consent
Minimal Tech Needed	VPN + MFA access to AWS Console; secondary gateway credentials (stored in Hardware Security Module); secure email for order intake
Data Capture	All manual orders logged in encrypted spreadsheet with timestamp, order ID, and customer contact; reconciled to primary system post-recovery
PCI-DSS Obligation	No card data to be stored in plaintext under any condition. Manual forms must be stored in locked, access-controlled storage. PCI-DSS incident report filed if metadata was exposed.
How to Reconcile	Batch upload manual order queue to payment system once primary gateway restored; fraud team validates all manually captured transactions

6.2 E-Commerce Platform / Online Selling (Tier 1 – CRITICAL)

Element	Details
Primary Threat Scenario	SQL injection causing DB lockout, DDoS causing availability loss, AWS region failure
Continuity Strategy	Failover to pre-configured backup AWS region (daily backup automation already in place per case study); activate CloudFront failover routing
Immediate Actions	1. WAF tuned to block attack signatures. 2. Auto-scaling activated to absorb load. 3. If DB unavailable, activate read-only mode on cached

Element	Details
Manual Workaround	catalog. 4. If full outage, deploy static 'maintenance' page with phone order line. Customer support agents accept orders via dedicated phone line; orders logged manually with reference numbers
Minimal Tech Needed	AWS CloudFront CDN (cached static content), VPN for DevOps access, SIEM for monitoring, secondary region RDS replica
How to Reconcile	Manual orders queued and entered into system post-recovery; customer order confirmations sent via email once online

6.3 Inventory Management (Tier 2 – HIGH)

Element	Details
Primary Threat Scenario	Inventory DB sync failure, data tampering, warehouse system outage
Continuity Strategy	Warehouse staff revert to manual stock sheets; paper-based pick/pack workflow activated; distribution center operates on last known stock snapshot
Manual Workaround	Printed inventory sheets distributed to warehouse floor; barcode scanners replaced with manual count sheets for high-volume SKUs
Minimal Tech Needed	Printed inventory backup (generated from last DB snapshot), internal email for warehouse-to-office communication, basic workstations with spreadsheet access
How to Reconcile	Full physical count performed at end of continuity period; delta reconciled against DB snapshot before system re-sync

6.4 Customer Support (Tier 3 – MEDIUM)

Element	Details
Primary Threat Scenario	VoIP system failure, CRM outage, HQ inaccessibility
Continuity Strategy	Redirect to email-only support; agents work remotely via VPN with minimal CRM access; auto-responder deployed to set customer expectations
Manual Workaround	Support agents use personal mobile phones (pre-issued list) and dedicated continuity email alias; tickets logged in shared encrypted spreadsheet
Minimal Tech Needed	VPN + MFA, personal mobile devices, continuity email alias (pre-configured), read-only CRM view if available
Remote Work Posture	Customer Support team has pre-approved remote work capability; agents instructed to use company-issued VPN only; no PII to be processed on personal devices without VPN
How to Reconcile	All continuity tickets imported into CRM post-recovery; duplicates and backlog addressed within 24 hours of restoration

6.5 Manual Mode Security Controls

- All manual forms and data captures containing PII or order data must be stored in locked physical storage (HQ) or encrypted digital files (remote)
- No credit card data, PAN, or CVV to be written down under any circumstances — manual orders reference gateway-generated token IDs only
- All paper forms must be destroyed via cross-cut shredder once reconciled to primary systems
- Shared continuity spreadsheets must be encrypted and access-controlled (password-protected, shared only via secure channel)
- Any staff accessing continuity systems remotely must use company-issued VPN with MFA enforced

7. People, Facilities & Alternate Work

7.1 Minimum Staffing Requirements

Process	Min. Staff	Key Skills Required	Cross-Training / Backup
Payment Processing	2	Fraud detection, PCI-DSS, gateway API	Fraud team + 1 trained DevOps member
E-Commerce / DevOps	3	AWS administration, WAF tuning, incident response	3 DevOps engineers with AWS certs; on-call rotation
Inventory / Warehouse	5	Pick/pack operations, manual stock counting	Cross-trained warehouse staff; supervisor can cover any role
Customer Support	3	Customer communication, ticket management, CRM basics	2 agents + 1 team lead remote-capable at all times
IT / SOC	2	SIEM monitoring, cloud operations, incident triage	SOC Lead + backup on-call; Fraud team cross-trained on SIEM basics

7.2 Alternate Sites & Remote Work

- Primary HQ: Main operations base — staff report here unless inaccessible

- Warehouse/Distribution Center: Secondary operations site; can host Customer Support in emergency given available workstations
- Remote Work: Customer Support and DevOps/IT are pre-approved for remote work with company VPN + MFA; no on-site requirement for these roles during activation
- Virtual EOC: All leadership coordination via video bridge (Zoom/Teams) with pre-shared dial-in credentials stored in the emergency contacts list

7.3 Cross-Training Plan

- DevOps to Fraud: At least 1 DevOps engineer trained on PCI-DSS reporting basics and secondary gateway activation quarterly
- Customer Support to Inventory: At least 2 support agents cross-trained on basic order fulfillment logging annually
- Fraud to IT: Fraud team members trained on SIEM alert triage to assist during SOC overload scenarios
- All critical continuity procedures documented in Appendix B (Runbooks) so any trained staff member can execute

8. Vendor & Dependency Management

8.1 Critical Vendors Table

Vendor	Service	SLA / RTO	Escalation Path	Continuity Gap	Gap Mitigation
AWS	Primary cloud hosting, EC2, RDS, WAF, CDN, SIEM	99.99% uptime per region SLA	AWS Business Support → TAM escalation via console	Single-region deployment; region failure = full outage	Daily backups to secondary AWS region (us-east-1 → us-west-2); IaC (Terraform/CDK) ready for rapid re-deploy
3rd-Party Payment Gateway	PCI-compliant payment authorization	99.95% per contract; 4-hour resolution SLA	Gateway NOC hotline → account manager → legal escalation	Single gateway provider — no failover. CRITICAL gap.	Identify and pre-integrate a secondary PCI gateway NOW. Store backup credentials in HSM. Manual order queue as last resort.
FedEx / UPS	Shipping label generation, carrier API, package tracking	Best-effort; 24-48h issue resolution	Carrier Integration API failover; carrier account rep	Heavy external API reliance; no fallback carrier	Pre-integrate second carrier API (e.g., USPS or DHL); manual label printing backup

Vendor	Service	SLA / RTO	Escalation Path	Continuity Gap	Gap Mitigation
SaaS Tools (CRM, VoIP)	Customer ticketing, agent communications	Per vendor SLA; typically 99.9%	Vendor support portal; direct account manager line	VoIP failure leaves agents without phone capability	Pre-configure mobile redirect; maintain email-only continuity mode

8.2 Upstream/Downstream Dependency Impact

Vendor/System Unavailable	Upstream Effect	Downstream Effect	Temporary Decoupling Plan
Payment Gateway	Checkout halts; revenue stops immediately	Order pipeline pauses; fraud engine idle	Activate secondary gateway; manual order queue; notify customers of payment delays
AWS (primary region)	All hosted systems down: website, API, DB, SIEM	No inventory updates, no order confirmations, no monitoring	Failover to backup AWS region; IaC redeploy; static site fallback
Inventory DB	Warehouse cannot fulfill orders accurately	Shipping halts or ships incorrect items	Manual stock sheet; halt new order processing until sync restored
FedEx/UPS API	Labels cannot be generated	Shipments delayed; customer delivery impacted	Switch to backup carrier API; manual label printing for priority orders

9. Communications Plan

9.1 Audience & Channels

Audience	Channel	Cadence During Incident	Owner
Internal Staff	Slack/Teams + Emergency Email + Phone Tree	Initial activation + every 2 hours	BCP Coordinator
Executives / Board	Direct phone call + email	Immediate activation notice + hourly executive briefings	CISO
Customers	Website banner + Email blast + Social media	Within 1 hour of confirmed outage; updates every 2 hours	Marketing + Support Lead

Audience	Channel	Cadence During Incident	Owner
Regulators (PCI-DSS / State)	Formal written notice + legal notification portal	Within 72 hours of confirmed data exposure (PCI-DSS requirement)	Legal / Privacy Lead
AWS / Payment Gateway	Vendor support hotline + account manager	Immediately upon activation; escalate if no response in 30 min	Vendor Manager
Shipping Partners	Carrier Integration API team + account rep email	Within 2 hours if shipping disrupted	Vendor Manager

9.2 Communication Templates

Template A — Internal Activation Notice

SUBJECT: [BCP ACTIVATION] ShopEase Business Continuity Plan — Incident Active

Team, the ShopEase Business Continuity Plan has been activated as of [TIME] on [DATE] due to [BRIEF DESCRIPTION OF EVENT]. Affected systems: [LIST]. All department leads please acknowledge receipt and activate your continuity runbooks immediately. EOC bridge link: [LINK]. Next update in 2 hours or sooner if conditions change. — [BCP COORDINATOR NAME]

Template B — Customer Notice (Checkout Disruption)

SUBJECT: Important Update on Your ShopEase Order Experience

We are currently experiencing a technical issue affecting our checkout process. Our team is actively working to resolve this. If you attempted to place an order and were not successful, please contact our support team at support@shopease.com or call [PHONE]. We apologize for the inconvenience and expect to restore full service by [ETA]. Your trust matters to us. — The ShopEase Team

Template C — PCI-DSS Regulator Notice

SUBJECT: PCI-DSS Incident Notification — ShopEase Online Retail — [INCIDENT ID]

ShopEase Online Retail is formally notifying [ACQUIRER/PCI SSC] of a security incident occurring on [DATE] affecting our payment processing environment. Nature of incident: [DESCRIPTION]. Data potentially involved: [METADATA DESCRIPTION — NO CARD DATA STORED ON-SITE]. Immediate containment actions taken: [LIST]. Ongoing investigation in progress. Contact: [LEGAL/PRIVACY LEAD], [EMAIL], [PHONE].

10. Data Capture, Protection & Integrity

10.1 RPO Alignment in Continuity Mode

Process	RPO Target	Continuity Data Capture Method	Frequency
Payment Processing	15 minutes	Encrypted manual order log + secondary gateway transaction records	Real-time (manual) / batch sync on recovery
E-Commerce Platform	30 minutes	AWS RDS read replica in secondary region (daily backup automation + point-in-time recovery enabled)	Continuous replication; hourly snapshot minimum
Inventory	4 hours	Manual stock sheets with timestamped entries per warehouse shift	Per-shift (every 4-8 hours)
Customer Support	12 hours	Shared encrypted spreadsheet of tickets; email thread preservation	End of each continuity shift

10.2 Data Protection Controls in Manual Mode

- PII Protection: All manual records containing customer names, addresses, or order data must be stored in locked cabinets (physical) or encrypted, access-controlled shared drives (digital)
- Payment Data: Absolutely no PAN, CVV, or cardholder authentication data to be written on any form. References to orders must use gateway-assigned token IDs only.
- Custody Log: Every manual form must have a custody log — who created it, when, and who has access — using the chain of custody template in Appendix D
- Transport: Any physical records transported between sites must use tamper-evident envelopes; digital transfers must use encrypted channels (VPN + SFTP minimum)
- Destruction: All paper records must be shredded via cross-cut shredder within 7 days of reconciliation to primary systems

10.3 Post-Recovery Reconciliation

- Finance/Fraud team performs transaction reconciliation between manual order log and primary system within 24 hours of recovery
- Inventory team performs delta reconciliation — manual counts vs. pre-outage DB snapshot — within 24 hours
- Customer Support team imports all continuity tickets into CRM within 24 hours; duplicates reviewed manually
- IT/DevOps validates data integrity of restored DB using hash verification and spot-check queries before enabling customer access

11. Transition: Continuity Mode to Full Recovery (DRP Handoff)

11.1 When to Transition

The BCP remains active until ALL of the following criteria are met:

- Primary AWS environment (or secondary failover region) is stable and validated — no ongoing attack or compromise
- Database integrity verified — data loss confirmed to be within RPO thresholds
- Payment gateway (primary or confirmed secondary) is operational and processing transactions
- Security team has confirmed threat is contained — no active exploit, malware, or unauthorized access
- IT Lead formally declares 'technical stabilization achieved' to BCP Coordinator

11.2 DRP Handoff Package

The following materials must be prepared by the BCP Coordinator before handing off to the DRP team:

- Complete manual order queue — all orders captured during continuity mode with timestamps and status
- Data reconciliation delta files — manual forms, spreadsheets, and inventory counts
- Incident timeline and evidence log — all actions taken, by whom, and when
- Outstanding vendor tickets and SLA claims — unresolved items with AWS, payment gateway, and carriers
- Customer communication log — all notices sent, channels used, and pending follow-ups
- Compliance status update — PCI-DSS reporting status, open regulatory items, legal review outstanding

11.3 Return to Normal Operations Checklist

#	Action	Owner	Status Field
1	Primary systems fully restored and load-tested	IT Lead	[] Complete
2	Payment gateway processing confirmed end-to-end	Fraud/Finance Lead	[] Complete
3	DB integrity validated; no unreconciled data loss beyond RPO	DevOps/IT Lead	[] Complete
4	Manual order queue batch-uploaded to primary system	Finance Lead	[] Complete
5	Inventory delta reconciled; stock counts synced	Warehouse Lead	[] Complete
6	Customer support backlog cleared and tickets in CRM	Support Lead	[] Complete
7	Security monitoring re-enabled; alerts confirmed active	SOC Lead	[] Complete
8	PCI-DSS reporting obligations fulfilled (if applicable)	Legal/Privacy Lead	[] Complete
9	Post-incident review meeting scheduled within 5 business days	CISO	[] Complete
10	CISO issues formal 'All Clear' notice to staff and stakeholders	CISO	[] Complete

12. Testing, Training & Exercises

12.1 BCP Test Schedule

Test Type	Frequency	Scope	Owner	Success Criteria
Tabletop Exercise	Semi-annual (every 6 months)	Simulate DDoS + SQL injection scenario; walk through activation, continuity strategies, and comms	CISO + BCP Coordinator	All roles can articulate their actions; no critical gaps identified
Communication Drill	Annual	Test emergency phone tree and EOC bridge; validate all contact information is current	BCP Coordinator	All leads reached within 15 minutes; EOC bridge functional
Secondary Gateway Failover Test	Annual (off-peak hours)	Activate secondary payment gateway in test mode; verify transaction processing	Fraud/Finance + IT Lead	Secondary gateway processes test transactions within 30 minutes
AWS Region Failover Test	Annual (scheduled maintenance window)	Validate backup region readiness; test IaC re-deployment; verify RDS replica promotion	DevOps/IT Lead	Recovery to secondary region completed within 4-hour RTO
Manual Inventory Drill	Annual	Warehouse team executes manual stock count using continuity forms; verify reconciliation process	Warehouse Ops Lead	Manual count reconciles with DB within 5% variance; forms completed correctly
Full BCP Activation Simulation	Bi-annual	Unannounced (or lightly announced) full BCP activation across all departments	CISO	Tier-1 processes in continuity mode within 1 hour; no critical failures

12.2 Lessons Learned Integration

- After every test and real activation: conduct a structured post-incident/post-exercise review within 5 business days
- Document findings in a Lessons Learned register; each finding assigned an owner and remediation deadline
- Lessons feed directly into BIA and BCP updates; no finding should remain open across two consecutive annual reviews
- November 28, 2025 Black Friday SQL Injection (IR-20251128-001): Findings from this real incident — specifically the staging-to-production patch gap — must be resolved before next BCP review cycle

12.3 Quality Gate

- After each exercise, BCP Coordinator compares BIA priority matrix to what the BCP actually protected — gaps reported to CISO within 10 business days
- Test reports, issue logs, and action items stored in secure document management system
- Any finding classified as 'Critical' (i.e., would have caused an MTD breach) must be remediated within 30 days of identification

13. Governance & Continuous Improvement

13.1 BCP Review & Update Triggers

- Annual mandatory review (minimum) — aligned with BIA refresh cycle
- After any real incident activation (e.g., Black Friday 2025 SQL injection)
- After any major infrastructure change — new cloud regions, new vendors, system migrations
- After significant regulatory change — new PCI-DSS version, state privacy law updates
- After any organizational change — new departments, significant staff/leadership changes, new third-party relationships
- After any BCP test that reveals critical gaps not previously identified

13.2 Continuous Improvement Actions (From Known Incidents & Risk Assessment)

Finding Source	Issue Identified	Recommended Action	Priority	Owner	Target Date
IR-20251128-001 (Black Friday)	Known vulnerability not patched from staging to production	Implement automated DevSecOps pipeline enforcing patch deployment parity between staging and production	CRITICAL	DevOps Lead	Q2 2026
Risk Assessment	Single payment gateway — no failover	Contract and integrate secondary PCI-compliant payment gateway as standby	CRITICAL	Finance / Vendor Mgr	Q2 2026
BIA / Risk Assessment	Insufficient DDoS protection	Deploy AWS Shield Advanced + CloudFront rate limiting; define auto-scaling thresholds for Black Friday season	HIGH	IT/Cloud Lead	Q2 2026
Risk Assessment	Backup recovery not tested	Schedule annual AWS region failover test; validate RDS point-in-time recovery quarterly	HIGH	DevOps Lead	Q3 2026
Risk Assessment	Incomplete SIEM alert coverage	Conduct SIEM tuning review; expand coverage to include DB	HIGH	SOC Lead	Q2 2026

Finding Source	Issue Identified	Recommended Action	Priority	Owner	Target Date
		query anomalies and API abuse patterns			
BIA	No formal secondary payment gateway MOU	Formalize SLA with backup gateway vendor; pre-test integration in staging environment	HIGH	Finance Lead	Q3 2026

14. Appendices

Appendix A — Emergency Contacts

Role	Name	Primary Phone	Alternate Phone	Email	Availability
CISO / BCP Coordinator	Christian Acevedo	[REDACTED]	[REDACTED]	c.acevedo@shopease.com	24x7
SOC Lead / IT Lead	Mathias Benkert	[REDACTED]	[REDACTED]	m.benkert@shopease.com	24x7 on-call
Finance / Fraud Lead	TBD	[REDACTED]	[REDACTED]	fraud@shopease.com	Business hours; on-call during peak
Legal / Privacy Lead	TBD	[REDACTED]	[REDACTED]	legal@shopease.com	Business hours; emergency line
Warehouse Ops Lead	TBD	[REDACTED]	[REDACTED]	warehouse@shopease.com	Business hours
Customer Support Lead	TBD	[REDACTED]	[REDACTED]	support-lead@shopease.com	Business hours; remote-capable
AWS Support	Account TAM	[REDACTED]	AWS Console Support	aws-support@amazon.com	24x7 Business Support
Payment Gateway NOC	Vendor Contact	[REDACTED]	[REDACTED]	[REDACTED]	24x7
FedEx API Support	Integration Team	[REDACTED]	[REDACTED]	[REDACTED]	Business hours

Appendix B — Continuity Runbooks (Summary)

Runbook B-1: Payment Processing Failover

1. Confirm payment gateway outage via vendor status page and AWS CloudWatch metrics
2. Retrieve secondary gateway credentials from Hardware Security Module (HSM) — requires 2-person authentication
3. Update payment API endpoint configuration in AWS Systems Manager Parameter Store to point to secondary gateway
4. Verify test transaction successfully processes through secondary gateway
5. Notify Finance Lead and CISO that failover is active; begin manual order queue logging
6. Log all manual actions in incident ticket; notify Fraud team to monitor for anomalies on secondary gateway

Runbook B-2: E-Commerce Platform Failover (DDoS / Outage)

7. Confirm outage via SIEM alerts, CloudWatch, and customer reports — classify as SEV1 if E-Commerce is down
8. Tune WAF rules to block identified attack patterns (SQL injection, volumetric flood signatures)
9. Enable AWS Shield Advanced DDoS protection if not already active; increase auto-scaling group limits
10. If primary region is degraded: initiate RDS replica promotion in secondary AWS region
11. Update CloudFront distribution to route traffic to secondary region endpoint
12. If full failover required: deploy static maintenance page via S3 static site + CloudFront; activate phone order line
13. Notify all stakeholders via Section 9 communications plan; update customer-facing status page

Appendix C — Alternate Sites & Access

Site	Address	Access Method	Key Contact	Notes
HQ (Primary)	ShopEase Headquarters — [ADDRESS REDACTED]	Standard badge access; emergency key held by Facilities Manager	Facilities Manager	Customer Support + Finance + Management
Warehouse/DC (Secondary)	ShopEase Distribution Center — [ADDRESS REDACTED]	Warehouse badge + supervisor override	Warehouse Ops Lead	Inventory + Logistics; can host Support agents in emergency
Virtual EOC	Zoom Bridge: [LINK REDACTED]; Dial-in: [REDACTED]	Pre-shared bridge ID in emergency contacts	CISO	Always-available; test monthly

Appendix D — Forms & Logs

The following forms are maintained in print-ready format at HQ and in the secure digital document store:

- D-1: Manual Order Capture Form (fields: Order ID, Customer Name, Contact, Items, Quantities, Payment Token Reference, Agent ID, Timestamp)

- D-2: Manual Inventory Count Sheet (fields: SKU, Item Description, Expected Qty, Counted Qty, Discrepancy, Counter ID, Timestamp)
- D-3: Continuity Ticket Log (fields: Ticket ID, Customer Contact, Issue Type, Priority, Agent, Created, Status)
- D-4: Chain of Custody Log (fields: Form/File ID, Created By, Date/Time, Transferred To, Transfer Method, Received By, Destruction Date)
- D-5: Reconciliation Checklist (used post-recovery to verify all manual data entered into primary systems)

Appendix E — Regulatory Matrix

Regulation	Trigger Condition	Notification Timeline	Notification Target	Owner
PCI-DSS	Confirmed or suspected exposure of cardholder data or payment transaction metadata	Immediately — report to acquiring bank and card brands; no specific hour window but 'prompt' required	Acquiring Bank, Card Brands (Visa/MC), PCI SSC	Legal/Privacy Lead + Fraud Team
State Data Breach Laws (FL)	PII of Florida residents exposed (names + financial/payment data)	30 days from determination of breach per Florida DBPA (Fla. Stat. 501.171)	Affected individuals + Florida AG if > 500 records	Legal/Privacy Lead
GDPR (if applicable)	EU customer PII exposed	72 hours from awareness of breach	Relevant EU Supervisory Authority	Legal/Privacy Lead
Internal SLA	Any SEV1 incident causing > \$10,000 revenue loss or > 1 hour Tier-1 outage	Immediate escalation to CISO; post-incident report within 5 business days	CISO, Executive Leadership	SOC Lead + BCP Coordinator

— END OF DOCUMENT —

ShopEase Online Retail | Business Continuity Plan v1.0 | April 2026 | CONFIDENTIAL